Nouvelles procédures et bonnes pratiques pour administrateurs et utilisateurs

REDACTEUR	VERSION	DATE	NATURE DES MODIFICATIONS
Beneteau Lucas	1.0	08/09/2025	Création du document

Ce document a pour but de décrire les nouvelles procédures et bonne pratique concernant la sécurisation du réseau de la société OpenPharma, en s'appuyant sur les recommandations de l'ANSSI.

En effet, à la suite de l'audit de sécurité, il a été constaté que plusieurs pratiques actuelles au sein de l'entreprise vont à l'encontre des règles de l'art en matière de cybersécurité. Ces faiblesses exposent potentiellement le système d'information à des risques de compromission, de perte de données sensibles ou encore d'interruption de service.

L'objectif de ce document est donc de présenter :

1. Les **évolutions et nouvelles procédures** mises en place.
2. Les **raisons** justifiant ces changements, en lien direct avec les risques identifiés.
3. Les **recommandations de l'ANSSI** correspondantes (captures d'écran), afin d'assurer la conformité avec les bonnes pratiques nationales.

Table des matières

1. Cadre et obligations à l'attention des administrateurs. 3
1.1. Rôles et responsabilités des administrateurs 3
1.2. Droits et devoirs des administrateurs 3
1.3. Documentation et traçabilité 3
2. Comptes et gestion des privilèges 4
2.1. Comptes nominatifs obligatoires 4
2.2. Interdiction des comptes génériques 4
2.3. Principe du moindre privilège 4
2.4. Mots de passe uniques et robustes imposés 5
2.5. Journalisation des événements liés aux comptes d'administration 5
3. Connexion à distance des administrateurs 6
4. Utilisation des e-mails. 7
5. Utilisation d'Internet 7
6. Sauvegarde et journalisation 8
6.1. Sauvegardes régulières et testées 8
6.2. Journalisation des actions d'administration 8

1. Cadre et obligations à l'attention des administrateurs.

1.1. Rôles et responsabilités des administrateurs

Les administrateurs sont des acteurs essentiels de la sécurité du système d'information. Leurs actions (installation, configuration, maintenance) peuvent avoir des conséquences critiques sur la disponibilité, l'intégrité et la confidentialité des données.
Ils disposent de privilèges élevés qui exigent un haut niveau de confiance, de compétence et de responsabilité.

1.2. Droits et devoirs des administrateurs

Conformément aux recommandations de l'ANSSI :

- **Loyauté** : l'administrateur s'engage à respecter les règles éthiques de l'organisation et à agir dans l'intérêt exclusif de celle-ci.
- **Confidentialité** : il est tenu au secret professionnel sur les informations techniques, organisationnelles ou métiers auxquelles il a accès.
- **Transparence** : ses actions doivent être traçables, vérifiables et conformes aux procédures en vigueur (charte informatique, règlement intérieur, contrats).
- **Compétence** : l'administrateur doit être formé régulièrement à la sécurité des systèmes d'information et aux évolutions technologiques.

R1

Informer les administrateurs de leurs droits et devoirs

Un administrateur doit être informé de ses droits et devoirs, notamment en s'appuyant sur la charte informatique de l'entité.
Il est recommandé d'élaborer une charte informatique spécifique applicable aux administrateurs.

1.3. Documentation et traçabilité

La documentation des systèmes doit être tenue à jour (schémas, inventaires, droits d'accès, cartographies),

R3

Disposer d'une documentation des SI à jour

Les administrateurs doivent disposer de documents reflétant fidèlement l'état courant des SI qu'ils administrent, notamment des cartographies du SI (physique, système, réseau, applications) faisant notamment apparaître clairement les interconnexions avec l'extérieur.

2. Comptes et gestion des privilèges

2.1. Comptes nominatifs obligatoires

Dorénavant, chaque employé dispose d'un compte nominatif et unique.
Chaque administrateur aura des comptes d'administration dédié, distincts de son compte utilisateur.
- Les comptes partagés sont interdits car ils ne permettent pas d'identifier précisément qui a effectué une action.

R27

Utiliser des comptes d'administration dédiés

L'administrateur doit disposer d'un ou plusieurs comptes d'administration dédiés, distincts de son compte utilisateur. Les secrets d'authentification doivent être différents suivant le compte utilisé.

2.2. Interdiction des comptes génériques

Les comptes de connexion root des applications de l'entreprise sont dorénavant proscrits pour les usages courants.
Leur utilisation n'est autorisée qu'en cas d'opération exceptionnelle.

Il en va de même pour les comptes root des systèmes d'exploitation.
- En effet, la compromission d'un tel compte donnerait un accès total au système, avec un risque critique pour l'entreprise.

R30

Utiliser par défaut des comptes d'administration individuels

Des comptes d'administration individuels doivent être attribués à chaque administrateur.
Les comptes natifs d'administration ne doivent pas être utilisés pour les actions courantes d'administration et les secrets associés ne doivent être accessibles qu'à un nombre très restreint de personnes.

2.3. Principe du moindre privilège

Chaque utilisateur ou administrateur n'a accès qu'aux ressources strictement nécessaires à sa mission.
- Les droits seront revus régulièrement pour éviter les accès inutiles.

2.4. Mots de passe uniques et robustes imposés

Tous les mots de passe doivent être :

1. **Robustes** ((longueur ≥ 12 caractères, majuscules, minuscules, chiffres, caractères spéciaux).
2. **Uniques** pour chaque application et service,
3. **Changés régulièrement** selon la nouvelle politique de sécurité.

- Un gestionnaire de mots de passe sécurisé sera déployé pour faciliter cette gestion.

R35

Stocker les mots de passe dans un coffre-fort de mots de passe

Il est recommandé d'utiliser un coffre-fort de mots de passe disposant d'un visa de sécurité pour stocker de manière sécurisée les mots de passe sur le SI d'administration. Ainsi, les mots de passe peuvent être, autant que possible, distincts, longs et aléatoires.

2.5. Journalisation des événements liés aux comptes d'administration

Tous les événements liés aux comptes d'administration doivent être enregistrés et audités.
- Cela permet de garantir la traçabilité des actions et de détecter rapidement une activité suspecte.

R31

Journaliser les événements liés aux comptes d'administration

Les mécanismes d'audit des événements concernant les comptes d'administration doivent être mis en œuvre. En particulier, les journaux suivants doivent être activés :

- ouvertures et fermetures de session ;
- échecs d'authentification et verrouillage des comptes ;
- gestion des comptes ;
- gestion des groupes de sécurité.

3. Connexion à distance des administrateurs

3.1 Connexion VPN (OpenVPN)

L'administrateur insère sa carte à puce dans le lecteur et saisit son code PIN personnel.

Le certificat stocké sur la carte est utilisé pour établir la connexion VPN.

- Aucun accès n'est possible sans la carte à puce et son code PIN.

3.2 Accès au bastion d'administration

Une fois connecté au VPN, l'administrateur se connecte au bastion d'administration.

L'authentification se fait en multi-facteur (MFA) soit : mot de passe + validation via téléphone.

3.3 Connexion aux serveurs depuis le bastion

L'administrateur se connecte aux serveurs cibles uniquement via des protocoles sécurisés (SSH avec clé, RDP avec TLS, HTTPS).

Les identifiants utilisés sont nominatifs et tracés.

- Aucune connexion directe depuis le VPN vers les serveurs n'est autorisée.

3.4 Clôture de la session

L'administrateur se déconnecte d'abord des serveurs, puis du bastion, et enfin du VPN.

4. Utilisation des e-mails.

- Ne jamais cliquer sur un lien ou ouvrir une pièce jointe suspecte.
  - Exemple : une facture inattendue, un fichier compressé inconnu, un document Office demandant d'activer les macros.
- Vérifier attentivement l'adresse de l'expéditeur avant d'agir.
  - Attention aux usurpations (ex. contact@openpharma.com vs contact@openpharm4.com).
- Ne jamais transmettre ses identifiants ou informations sensibles par e-mail.
  - Le service informatique ne vous demandera jamais vos mots de passe par mail.
- Signaler immédiatement tout e-mail suspect en le transférant au service informatique.

5. Utilisation d'Internet

- Utiliser Internet uniquement à des fins professionnelles.
  - Les sites personnels augmentent les risques d'infection.
- Ne jamais télécharger de logiciels, extensions ou fichiers sans validation du service IT.
  - Même une extension de navigateur peut contenir un malware.
- Éviter de se connecter à des services externes (boîtes mail perso, réseaux sociaux) avec son adresse professionnelle, sauf nécessité.
  - Cela limite le risque d'exposition de données sensibles.

6. Sauvegarde et journalisation

6.1. Sauvegardes régulières et testées

Les configurations des serveurs, équipements réseaux et applications métiers doivent être sauvegardées régulièrement.
Chaque sauvegarde est stockée de manière sécurisée sur un serveur de sauvegarde dédié, et une copie supplémentaire est conservée hors ligne sur bandes magnétiques afin de garantir une restauration même en cas de compromission du système principal.

- Les sauvegardes doivent être isolées et testées périodiquement pour s'assurer de leur bon fonctionnement.

R45

Définir une politique de sauvegarde du SI d'administration

Pour permettre de pallier la corruption ou l'indisponibilité de données dues à un incident ou une compromission, une politique de sauvegarde doit être définie et appliquée pour le SI d'administration.
Pour les éléments les plus critiques, une sauvegarde hors ligne doit être prévue.

6.2. Journalisation des actions d'administration

Toutes les actions d'administration doivent être obligatoirement journalisées (connexions, élévations de privilèges, modifications de configurations, gestion des comptes, etc.).
Les journaux sont centralisés et protégés contre toute modification non autorisée.

- L'accès aux journaux est réservé au service sécurité et aux responsables habilités.

R46

Dédier une zone d'administration à la journalisation

Il est recommandé de dédier une zone d'administration à la journalisation du SI administré et du SI d'administration. Le cas échéant, un contrôle d'accès spécifique doit être mis en place.

R47

Centraliser la collecte des journaux d'événements

L'architecture doit prévoir la transmission des journaux d'événements de manière centralisée, depuis les équipements vers les services de journalisation.

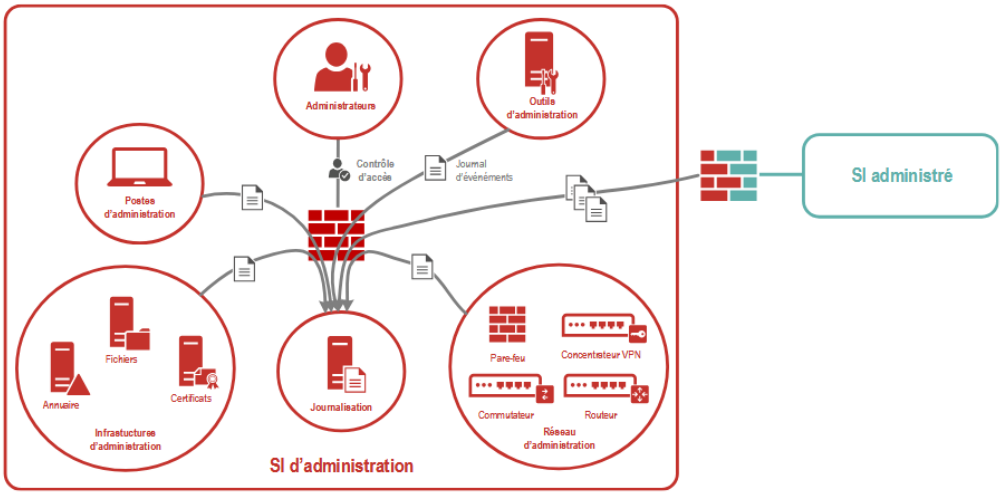

FIGURE 9.1 – Représentation fonctionnelle de la journalisation au sein du SI d'administration